

Security+ 5.3 · Agreement Types

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.3** —
Agreement Types (5:19) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: SLA: service metric + PENALTY if missed (99.9% uptime); MOU/MOA (intent); NDA (confidentiality); BPA (formal partnership).

High-Yield Core Concepts Tested on Exam

- SLA: service metric + penalty if failed
- MOU/MOA: expresses intent, typically not legally binding
- NDA: confidentiality agreement
- BPA: formal partnership agreement with shared responsibilities
- SLA defines measurable service levels and consequences for non-compliance

Exam Tips & Classic Scenarios

- 'agreement defining service level penalty' = SLA
- 'agreement expressing intent without legal obligation' = MOU/MOA
- 'agreement protecting confidential information' = NDA
- 'formal partnership agreement' = BPA

Typical Exam Scenario: 'Contract with vendor defining 99.9% uptime and penalty' = SLA.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.3 — Agreement Types)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Agreement that defines the SERVICE LEVEL (e.g., 99.9% availability) between vendor and customer:

- A)** SLA
- B)** MOU
- C)** NDA
- D)** BPA

2. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'SLA: service metric + penalty if failed'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: SLA: service metric + penalty if failed...

3. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'agreement defining service level penalty'=SLA'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'agreement defining service level penalty'=SLA...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'vendor contract defining 99.9% uptime and penalty' = SLA. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'vendor contract defining 99.9% uptime and penalty' = SLA.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'SLA: service metric + penalty if failed'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: SLA: service metric + penalty if failed...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'agreement defining service level penalty' = SLA. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'agreement defining service level penalty' = SLA...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'contract with supplier defining 99.9% uptime and penalty'=SLA. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'contract with supplier defining 99.9% uptime and penalty'=SLA...
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'SLA: service metric + penalty if failed'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: SLA: service metric + penalty if failed...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'agreement defining service level penalty'=SLA. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'agreement defining service level penalty'=SLA...
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Agreement Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'contract with vendor defining 99.9% uptime and penalty'=SLA.'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'contract with vendor defining 99.9% uptime and penalty'=SLA....
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — SLA.

✓ **Why it's correct:** SLA (Service Level Agreement) is a formal and measurable agreement between a service provider and a customer that explicitly defines expected service levels, including metrics such as availability (e.g., 99.9%), response time, throughput, maintenance windows, and penalties for non-compliance. In the context of CompTIA Security+ (domain 5.1 – Governance, Risk, and Compliance), the SLA is the contractual document that establishes performance obligations and serves as the basis for auditing and vendor management. The question asks exactly for the agreement that defines service level, and the SLA is the only one that carries this definition in its own name and scope.

✗ Why the others are wrong:

- **MOU:** MOU (Memorandum of Understanding) is a document that expresses a mutual understanding between the parties, generally used in early negotiation phases or to formalize intentions of cooperation without creating legally binding obligations. It does not establish quantitative service level metrics, such as availability percentages, nor does it provide penalties for unsatisfactory performance. Therefore, it does not meet the requirement of defining a measurable service level between vendor and customer.
- **NDA:** NDA (Non-Disclosure Agreement) is a legal agreement focused exclusively on protecting confidential information, preventing the parties from disclosing trade secrets, proprietary data, or sensitive information exchanged during the relationship. Its scope is confidentiality, not operational performance. There is no typical NDA clause that establishes availability levels, response time, or other service metrics, making it completely unsuitable for the purpose described in the statement.
- **BPA:** BPA (Business Partnership Agreement) is an agreement that governs the formation, governance, and responsibilities of a business partnership between two or more organizations, addressing aspects such as profit sharing, intellectual property, decision-making, and dispute resolution. Although it may contain clauses about service levels, its main focus is the partnership structure itself, not the definition of operational service metrics. The statement specifically asks for the agreement that defines the service level, and the BPA does not have this primary purpose.

2) D — Implement the corresponding solution: SLA: service metric + penalty if failed....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): SLA: service metric + penalty if failed.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: 'agreement defining service level penalty'=SLA....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 5.3 (Agreement Types): 'agreement defining service level penalty'=SLA. A Service Level Agreement (SLA) defines the expected level of service, metrics for measuring performance, and penalties or remedies if the provider fails to meet those levels. It is a contractual agreement between a service provider and a customer.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: 'vendor contract defining 99.9% uptime and penalty' = SLA..

✓ **Why it is correct:** Per the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): 'vendor contract defining 99.9% uptime and penalty' = SLA. An SLA (Service Level Agreement) is a formal contract between a service provider and a customer that specifies measurable performance guarantees — such as uptime percentage, response times, and remediation timelines — along with penalties or remedies for failing to meet those guarantees. It is a key administrative control used in third-party risk management and vendor governance.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: SLA: service metric + penalty if failed....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): SLA: service metric + penalty if failed. A Service Level Agreement (SLA) defines the expected level of service, often including metrics such as uptime, response time, and penalties for non-compliance. It is a contractual agreement that ensures accountability and performance.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: 'agreement defining service level penalty' = SLA....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): 'agreement defining service level penalty' = SLA.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) C — Implement the corresponding solution: 'contract with supplier defining 99.9% uptime and penalty'=SLA....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): 'contract with supplier defining 99.9% uptime and penalty'=SLA. A Service Level Agreement (SLA) specifies performance metrics such as uptime and penalties for non-compliance, ensuring service quality.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: SLA: service metric + penalty if failed....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): SLA: service metric + penalty if failed. A Service Level Agreement (SLA) defines the expected level of service, metrics for measuring performance, and penalties or remedies if the provider fails to meet those levels. It is a contractual agreement between a service provider and a customer.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: 'agreement defining service level penalty'=SLA....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): 'agreement defining service level penalty'=SLA. A Service Level Agreement (SLA) defines the expected level of service, including uptime, performance metrics, and penalties for non-compliance. It is a contractual agreement between a service provider and a customer.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: 'contract with vendor defining 99.9% uptime and penalty'=SLA.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Agreement Types): 'contract with vendor defining 99.9% uptime and penalty'=SLA.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.